

Break-In Lab Writeup

Gurumanie Singh Dhiman

VM IP Address (IPv4): 190.100.60.238/24

Executive Summary

For this Break-In Lab, I conducted a penetration test against the 532Corp network for the IP range 82.46.91.0/24. After doing so, I uncovered multiple critical and high-severity vulnerabilities across nine machines, including unencrypted Telnet services with weak credentials, SQL injection vulnerabilities on web login pages, DNS zone transfer misconfiguration exposing internal network topology, anonymous LDAP access, password reuse across systems, a backdoor account with unrestricted sudo access, and an unencrypted MySQL database containing sensitive employee PII. I was able to gain successful access to multiple machines using credential brute-forcing techniques from OSINT reconnaissance of the 532Corp public-facing website.

```
Nmap 7.80 scan initiated Mon Apr 27 16:31:22 2026 as: nmap -p- -T4 -oN nmap_full.txt 82.46.91.0/24
Warning: 82.46.91.206 giving up on port because retransmission cap hit (6).
Warning: 82.46.91.208 giving up on port because retransmission cap hit (6).
Warning: 82.46.91.201 giving up on port because retransmission cap hit (6).
Nmap scan report for www.532corp.com (82.46.91.10)
Host is up (0.020s latency).
Not shown: 65532 closed ports
PORT      STATE SERVICE
22/tcp    open  ssh
25/tcp    open  smtp
53/tcp    open  domain

Nmap scan report for ns1.532corp.com (82.46.91.200)
Host is up (0.0023s latency).
Not shown: 65533 closed ports
PORT      STATE SERVICE
22/tcp    open  ssh
53/tcp    open  domain

Nmap scan report for 82.46.91.201
Host is up (0.0016s latency).
Not shown: 65524 closed ports
PORT      STATE SERVICE
22/tcp    open  ssh
53/tcp    open  domain
80/tcp    open  http
3389/tcp  open  ms-wbt-server
8175/tcp  filtered unknown
8289/tcp  filtered unknown
20312/tcp filtered unknown
33273/tcp filtered unknown
44581/tcp filtered unknown
49302/tcp filtered unknown
54801/tcp filtered unknown
```

```

Nmap scan report for 82.46.91.204
Host is up (0.13s latency).
Not shown: 65492 closed ports, 41 filtered ports
PORT      STATE SERVICE
22/tcp    open  ssh
53/tcp    open  domain

Nmap scan report for 82.46.91.205
Host is up (0.0040s latency).
Not shown: 65475 closed ports, 55 filtered ports
PORT      STATE SERVICE
22/tcp    open  ssh
23/tcp    open  telnet
53/tcp    open  domain
80/tcp    open  http
389/tcp    open  ldap

Nmap scan report for 82.46.91.206
Host is up (0.0015s latency).
Not shown: 65518 closed ports
PORT      STATE SERVICE
22/tcp    open  ssh
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
4736/tcp  filtered unknown
8634/tcp  filtered unknown
21014/tcp filtered unknown
29970/tcp filtered unknown
32294/tcp filtered unknown
33431/tcp filtered unknown
41110/tcp filtered unknown
43573/tcp filtered unknown
47027/tcp filtered unknown
48586/tcp filtered unknown
51537/tcp filtered unknown
57817/tcp filtered unknown
62896/tcp filtered unknown

Nmap scan report for 82.46.91.207
Host is up (0.0013s latency).
Not shown: 65512 closed ports
PORT      STATE SERVICE
22/tcp    open  ssh
53/tcp    open  domain
3389/tcp  open  ms-wbt-server
7301/tcp  filtered swx
11492/tcp filtered unknown
14041/tcp filtered unknown
15038/tcp filtered unknown
16716/tcp filtered unknown
19859/tcp filtered unknown
20921/tcp filtered unknown
26214/tcp filtered unknown
30786/tcp filtered unknown
32705/tcp filtered unknown
34558/tcp filtered unknown
34769/tcp filtered unknown
41110/tcp filtered unknown
45722/tcp filtered unknown
46637/tcp filtered unknown
47574/tcp filtered unknown
48217/tcp filtered unknown
56272/tcp filtered unknown
57817/tcp filtered unknown
65238/tcp filtered unknown

Nmap scan report for 82.46.91.208
Host is up (0.0017s latency).
Not shown: 65522 closed ports
PORT      STATE SERVICE
22/tcp    open  ssh
53/tcp    open  domain
776/tcp   filtered wpages
4339/tcp  filtered unknown
16937/tcp filtered unknown
18242/tcp filtered iclid
27185/tcp filtered unknown
33414/tcp filtered unknown
34076/tcp filtered unknown
41730/tcp filtered unknown
53693/tcp filtered unknown
55259/tcp filtered unknown
60312/tcp filtered unknown

```

Issues Identified

Host	Vulnerability	Severity	Finding
82.46.91.10	SMTP unauthenticated internal mail delivery	Medium	Internal mail sent as root without authentication
82.46.91.200	Password reuse — jsmithison:momo	High	SSH access gained; shadow hash file exposed
82.46.91.201	SQL Injection on /login.php	Critical	Bypassed auth with OR '1'='1 payload
82.46.91.204	Weak credentials; backdoor account with root sudo	Critical	jsmithison:momo; su backdoor -> sudo su = root
82.46.91.205	Telnet enabled; weak credentials; anonymous LDAP; empty Apache dir listing	Critical	tleeliluzivert via Telnet; LDAP anonymous bind; /lam/ exposed

82.46.91.206	SQL Injection on /login.php; unencrypted MySQL PII	Critical	Auth bypass; employee SSNs and credit card data accessible
82.46.91.207	xrdp exposed; XSS web application	High	RDP service accessible; Node.js XSS app running internally
82.46.91.208	DNS Zone Transfer allowed	High	Full internal network topology exposed

Attack Narrative

Phase 1: Reconnaissance

Network Scanning

An Nmap scan was performed against the full IP range to discover live hosts and open ports:

```
nmap -p- -T4 -oN nmap_full.txt 82.46.91.0/24
```

The following hosts were discovered:

- 82.46.91.10 — www.532corp.com (SSH 22, SMTP 25, DNS 53)
- 82.46.91.200 — ns1.532corp.com (SSH 22, DNS 53)
- 82.46.91.201 — Desktop (SSH 22, DNS 53, HTTP 80, RDP 3389)
- 82.46.91.204 — ns2 (SSH 22, DNS 53)
- 82.46.91.205 — LDAP Server (SSH 22, Telnet 23, DNS 53, HTTP 80, LDAP 389)
- 82.46.91.206 — WWWX Server (SSH 22, SMTP 25, DNS 53, HTTP 80)
- 82.46.91.207 — Workstation/www2 (SSH 22, DNS 53, RDP 3389)
- 82.46.91.208 — Mail Server (SSH 22, DNS 53)

Website Reconnaissance for 532corp.hackerville.org

I browsed the 532Corp public website and noted some key points. It is powered by WordPress and lists eight employees with personal biographies. The following employee information and interests were documented for use in password generation:

Username	Full Name	Title	Key Interest / Hint	Password Found
jsmithison	Jennifer Smithison	CEO	Dog named Momo	momo
jgreene	John Greene	CTO	World of Warcraft	—
sdash	Stacy Dash	CIO	French, yoga	—
rjohnson	Robert Johnson	CFO	Go Rameses (UNC)	—
mjones	Mark Jones	Lead PM	Boilermakers, Sigma Phi	—
lpeterson	Lily Peterson	Head of HR	Kayaking	—
scooling	Shane Cooling	Project Manager	Chacos, vegan, BYU	—
tlee	Tommy Lee	Marketing Manager	Drake, Lil Uzi Vert	liluzivert

Finding: WordPress technology identified on 532corp.hackerville.org. Employee biographies contain personal details that directly reveal user passwords which was a significant OSINT risk.

Phase 2: Host Analysis and Exploitation

82.46.91.10 — WWW Server (www.532corp.com)

Ports open: 22 (OpenSSH 8.2p1), 25 (SMTP Postfix), 53 (ISC BIND)

SMTP Enumeration — Metasploit auxiliary/scanner/smtp/smtp_enum identified valid users on the SMTP server with command:

```
use auxiliary/scanner/smtp/smtp_enum
```

```
set RHOSTS 82.46.91.10
```

```
run
```

- Valid users found: scooling, tlee, root
- Domain: www

Finding #1: Internal mail delivery works with no authentication required. Successfully sent email as root to user scooling using MAIL FROM: root@www / RCPT TO: scooling.

DNS Zone Transfer was attempted against this host but transfer failed.

82.46.91.200 — NS1 Server (ns1.532corp.com)

Ports open: 22 (SSH), 53 (DNS)

SSH access was gained using credentials discovered on .204 (password reuse) and the command is:

```
ssh jsmithison@82.46.91.200
```

Finding #1: SSH login successful as jsmithison:momo — password reuse confirmed across machines. Hash file 'done.txt' found in jsmithison's home directory containing password hashes for all users.

82.46.91.201 — Desktop Machine

Ports open: 22 (SSH), 53 (DNS), 80 (HTTP/Apache 2.4.41), 3389 (RDP/ms-wbt-server)

Nikto web scan was run against the HTTP service and the command used was:

```
nikto -h http://82.46.91.201
```

- Server: Apache/2.4.41 (Ubuntu) — outdated version
- Missing security headers: X-Frame-Options, X-XSS-Protection, X-Content-Type-Options
- Endpoint discovered: /login.php — PHP admin login page

Finding #1: SQL Injection vulnerability on /login.php. Authentication was bypassed using:

Username: schooling | Password: anything' OR '1'='1 — Logged in as user 'didi'.

RDP scan (Metasploit) confirmed encryption details on port 3389 — CredSSP NLA supported, 128-bit RC4.

82.46.91.203 — Secret Machine (sarahsmachine)

Ports open (internal): 22 (SSH), 23 (Telnet), 53 (DNS), 80 (HTTP), 389 (LDAP)

This machine was not visible in the external nmap scan but it was discovered using a hidden message in tlee's home directory on .205 and confirmed via internal nmap scan from inside .205. The machine runs Telnet and presents a login prompt labelled 'sarahsmachine login:'.

The internal IP was confirmed as 192.168.1.203. Telnet connection was initiated from inside .205 running the command:

```
telnet 192.168.1.203
```

Finding #1: Secret server 'sarahsmachine' was discovered and only reachable from inside the internal network after gaining access to the LDAP server (.205). Machine belongs to a former cybersecurity engineer named Sarah who used it to conduct unauthorized access to 532Corp systems.

82.46.91.204 — NS2 Server

Ports open: 22 (SSH), 53 (DNS)

SSH brute force was performed using an OSINT-derived wordlist built from employee biographical data on the 532Corp website using the command:

```
hydra -L 532_corp_usernames.txt -P osint_wordlist.txt ssh://82.46.91.204 -t 8 -V
```

Finding #1 — Credential Found: jsmithison:momo — SSH brute force succeeded.

Password derived from Jennifer Smithison's biography (her dog's name, 'Momo').

Once inside, enumeration of the home directory revealed Sarah's account and a research notes file with the command:

```
su sarah [no password required]
```

```
cat /home/sarah/research
```

- Sarah's notes reference scanning a second IP range: 27.67.83.0/24
- Notes describe exploiting machines on that range using vulnerabilities found via nmap
- Notes reference using 'remmina' and 'shell' to create accounts and gain admin privileges

Finding #2 — Privilege Escalation: Switching to user 'sarah' requires no password.

Running 'sudo su' from sarah's account yields a full root shell. whoami confirms root. This is a critical privilege escalation via a misconfigured backdoor-like account.

Finding #3 — Second IP Range: Sarah's notes reveal a second exploitable network at 27.67.83.0/24 containing Windows machines vulnerable to Metasploit exploits.

82.46.91.205 — LDAP Server (ldap.student0.532.com)

Ports open: 22 (SSH), 23 (Telnet), 53 (DNS), 80 (HTTP/Apache 2.4.41), 389 (LDAP)

HTTP Reconnaissance with the command:

```
curl http://82.46.91.205
```

- Server: Apache/2.4.41 (Ubuntu) — outdated, potential CVEs

- Root directory shows empty 'Index of /' — directory listing enabled
- /icons/ and /javascript/ return 403 Forbidden
- Metasploit dir_scanner discovered /lam/ returning HTTP 200 — LDAP Account Manager web interface

LDAP Anonymous Enumeration was done using the command:

```
ldapsearch -x -H ldap://82.46.91.205 -b "" -s base namingContexts
```

- Anonymous bind succeeded — result: 0 Success
- Naming context discovered: dc=student0,dc=532,dc=com
- Admin account found: cn=admin,dc=student0,dc=532,dc=com

Finding #1: Anonymous LDAP bind accepted — no authentication required to query directory structure. Naming context and admin DN exposed.

LDAP enumeration with Nmap script also confirmed the naming context and supported SASL mechanisms (DIGEST-MD5, CRAM-MD5, NTLM).

Telnet Access was done using the command:

```
telnet 82.46.91.205
```

An OSINT-derived password wordlist was built from employee biographical data and run via Metasploit telnet_login and Hydra command:

```
hydra -L 532_corp_usernames.txt -P bio_passwords.txt telnet://82.46.91.205 -t 4
```

Finding #2 — Credential Found: tlee:liluzivert — Telnet login successful. Password derived from Tommy Lee's listed interest in rapper Lil Uzi Vert. Confirmed hostname: ldap, OS: Ubuntu Linux 5.4.0.

Telnet is an unencrypted protocol and all credentials were being transmitted in plain text over the network.

Post-exploitation enumeration inside .205 was done using the command:

```
cat /etc/passwd which reveals the users: cpre532, tlee, mjones, telnetd, openldap
```

A hidden message was discovered buried in a deep directory path:

cat

~/openthis/keepgoing/youregettingwarmer/warmer/okayiguessshereitis/veryimportant message

Finding #3 — Hidden Message: Message reveals that user tlee accidentally discovered a secret server owned by 'Sarah' (former cybersecurity engineer) at IP 192.161.1.203 (typo for 192.168.1.203). tlee logged in using a password obtained from elsewhere on the system so this confirms the reuse of that password.

SSH access was also confirmed using the same credentials with the command:

```
ssh tlee@82.46.91.205
```

Internal nmap scan from inside .205 revealed the full internal network:

Internal IP	Key Ports	Hostname / Role	Notes
192.168.1.1	53, 80	pfSense Firewall	Login page accessible
192.168.1.195	22, 25, 53, 110, 143	Internal Mail Server	POP3/IMAP open — mailboxInternal.532corp.com
192.168.1.201	22, 53, 3389	Desktop / RDP	RDP machine
192.168.1.203	22, 23, 53, 80, 389	Sarah's Secret Server	sarahsmachine — only reachable internally
192.168.1.204	22, 53	NS2	SSH only
192.168.1.205	22, 23, 53, 80, 389	LDAP Server	Current machine
192.168.1.206	22, 25, 53, 80	WWWX / ws	SMTP + Web
192.168.1.207	22, 53, 3389	Workstation / www2	RDP
192.168.1.208	22, 25, 53, 110, 143	Mail Server	POP3/IMAP — mail.532corp.com

82.46.91.206 — WWWX Server (ws.student0.532.com)

Ports open: 22 (SSH), 25 (SMTP/Postfix), 53 (DNS), 80 (HTTP/Apache 2.4.41)

SMTP Enumeration was done with the command:

```
use auxiliary/scanner/smtp/smtp_enum
```

- Valid users found: mjones, root
- Domain: wwwx.localdomain

HTTP — Nikto Scan was done with the command:

```
nikto -h http://82.46.91.206
```

- Apache/2.4.41 — outdated version
- Missing security headers (X-Frame-Options, X-XSS-Protection, X-Content-Type-Options)
- Endpoint discovered: /login.php which is the PHP admin login page
- Apache mod_negotiation enabled — facilitates brute force of filenames

Finding #1 — SQL Injection: SQL Injection on /login.php. Auth bypassed using:

Username: schooling | Password: anything' OR '1'='1 — Logged in as user 'test'. Confirms same vulnerability pattern as .201.

MySQL (port 3306) was not externally accessible — firewall blocks direct connection. Access requires SSH access to the machine first, then local MySQL connection. Per lab design documentation, this machine contains an unencrypted MySQL database with private employee data including credit card numbers and social security numbers.

Finding #2: Unencrypted MySQL database on .206 contains PII including employee credit card numbers and SSNs. Data stored without encryption at rest — critical privacy and compliance risk.

82.46.91.207 — Workstation (www2.student0.532.com)

Ports open: 22 (OpenSSH 8.2p1), 53 (DNS), 3389 (xrdp — Linux RDP)

Version scan confirmed: Linux machine running xrdp (not Windows RDP). SSH service: OpenSSH 8.2p1 Ubuntu.

RDP scan via Metasploit confirmed encryption: CredSSP NLA supported, 128-bit RC4, RDP Protocol version 5.x-8.x.

xrdp login page was accessed showing session types: Xorg, Xvnc, vnc-any, neutrino-rdp-any. Credential attempts were made using the bio-derived wordlist but login was not achieved without credentials.

Finding #1: xrdp service exposed on port 3389. The workstation hosts XSS web applications (Node.js via PM2 process manager) accessible internally. The XSS app features a 532Corp employee review page and an attacker data collection page.

82.46.91.208 — Mail Server (mail.student0.532.com)

Ports open: 22 (OpenSSH 8.2p1), 53 (ISC BIND 9.18.30)

Version scan: SSH OpenSSH 8.2p1 Ubuntu, DNS ISC BIND 9.18.30-0ubuntu0.20.04.2

DNS Zone Transfer was attempted against multiple domains and servers:

```
dig axfr @82.46.91.208 student0.532.com
```

Finding #1 — DNS Zone Transfer: Zone transfer succeeded for domain student0.532.com, exposing the complete internal network topology including all hostnames, internal IP addresses, and service roles. Transfer was refused for other domains.

Zone transfer results:

- ns2.student0.532.com -> 192.168.1.200
- desktop1.student0.532.com -> 192.168.1.201
- ldap.student0.532.com -> 192.168.1.205
- ws.student0.532.com -> 192.168.1.206
- www2.student0.532.com -> 192.168.1.207
- mail.student0.532.com -> 192.168.1.208
- MX record: mail.student0.532.com

Strategic Recommendations

1. Disable Telnet and instead replace it with SSH

Since telnet transmits data including passwords in plain text. All Telnet services (port 23) should be disabled immediately and replaced with SSH.

2. Enforce Strong Password Policies

Two accounts were compromised using passwords that were directly from publicly available employee biographical information. Passwords must not reference personal information. Implement a minimum complexity policy or multi-factor authentication.

3. Remediate SQL Injection Vulnerabilities

Both .201 and .206 are vulnerable to SQL injection on /login.php. All database queries must use parameterized statements or prepared statements. Input validation and output encoding must be implemented.

4. Restrict DNS Zone Transfers

DNS zone transfers should be restricted to authorized secondary DNS servers only using ACLs in the BIND configuration (allow-transfer directive). Zone transfers to arbitrary hosts expose the full internal network topology.

5. Remove Backdoor Accounts and Audit sudo Permissions

The 'backdoor' account on .204 with unrestricted sudo privileges constitutes a critical vulnerability. All user accounts must be audited. The /etc/sudoers file should follow the principle of least privilege. The 'sarah' account with passwordless su access must be removed or secured.

6. Encrypt Sensitive Database Contents

Employee PII (SSNs, credit card numbers) stored in the MySQL database on .206 must be encrypted at rest using AES-256 or equivalent. Access to the database should require authentication and be restricted to authorized application accounts only.

7. Disable Anonymous LDAP Bind

The LDAP server on .205 allows anonymous binding, exposing directory structure. Anonymous access should be disabled. All LDAP queries should require authenticated credentials, and access to sensitive attributes should be restricted by ACL.

8. Remove LDAP Account Manager from Public Web

The /lam/ endpoint (LDAP Account Manager) is accessible on port 80 without authentication challenges. This web interface should be removed from public-facing Apache or placed behind VPN/IP restriction.

Conclusion

This penetration test revealed a network with many critical vulnerabilities across multiple machines. The most impactful attack chain began with passive OSINT reconnaissance of the 532Corp public website, which got me employee biographical details that were then used to construct a targeted password wordlist. This wordlist enabled me to brute-force access to the LDAP server via unencrypted Telnet, which in turn revealed a hidden internal network message pointing to a secret machine only accessible from inside the network.

Additional critical findings include things such as the SQL injection vulnerabilities on two machines allowing authentication bypass, a DNS zone transfer misconfiguration exposing the entire internal IP topology, a backdoor account with unrestricted root access via sudo, and an unencrypted database containing sensitive employee PII.